

IR Triage Report

Front Matter

ANALYST NAME: Jeremy Grantham

DATE: 2026-03-25

SOURCE: AWS CloudTrail via SIEM

ALERT ID: UR-AWS-20180820-0038

SEVERITY: CRITICAL ▾

DISPOSITION: True Positive (TP) ▾

Initial Findings

This alert flagged unusual AWS IAM activity involving a high volume of sensitive API calls. The investigation confirmed a True Positive incident where a compromised high-privileged account was used to transition a production S3 bucket to public, followed by unauthorized data staging and cryptomining. The scope included a compromised web server and multiple user endpoints, resulting in a Critical severity assessment due to the successful breach of the cloud control plane and subsequent lateral impact as well as TA gaining root access. .

Incident Summary

Activity was observed between 2018-08-20 09:16:12 UTC and 2018-08-20 15:15:04 UTC, spanning a total duration of 5 hours and 59 minutes.

- 09:16:12 UTC:TA uses leaked keys (AKIAJOGCDXJ5NW5PXUPA) to attempt creating a new access key for a shadow user (nullweb_admin).
- 2018-08-20 09:16:55 UTC Amazon Support reaches out with ticket 5244329601
- 2018-08-20 09:36:26 UTC: Initial suspicious CPU spike detected in a browser process on workstation BSTOLL-L, indicating the attacker pivoted from IAM manipulation to endpoint cryptomining.
- 2018-08-20 09:55:14 UTC Phishing email with W97M.Empstage received to broaden the foothold beyond the leaked IAM account.
- 2018-08-20 10:08:35 UTC Obfuscated PowerShell creates admin user svcvnc and disables AMSI/Logging.
- 2018-08-20 10:42:49 UTC PowerShell drops hdoor.exe backdoor into C:\Windows\Temp.
- 2018-08-20 10:47:05 UTC User interacts with phishing content, triggering a TCP request to download the attacker's toolkit masked as /images/logos.png.
- 2018-08-20 11:09:05 UTCAttacker leverages the downloaded toolkit to exploit the Tomcat service and escalate to root on the web server.
- 2018-08-20 11:32:14 UTC Confirmed C2 Session: PowerShell check-in to 45.77.53.176 via /admin/get.php and /news.php.
- 2018-08-20 13:01:46 UTC: Attacker uses compromised credentials to change S3 bucket frothlywebcode permissions to "public."
- 2018-08-20 13:02:44 UTC: Malicious text file OPEN_BUCKET_PLEASE_FIX.txt is uploaded to the exposed S3 bucket.
- 2018-08-20 13:04:17 UTC: Large archive file frothly_html_memcached.tar.gz (2.93 MB) is staged in the public S3 bucket.

- 2018-08-20 13:27:17 UTC: Endpoint MKRAEUS-L establishes the first successful outbound connection to the coinhive.com C2 mining pool.
- 2018-08-20 13:37:40 UTC: Endpoint BTUN-L successfully blocks an attempted download of the JSCoinminer malware.
- 2018-08-20 13:37:50 UTC: Unauthorized cryptocurrency mining begins on BSTOLL-L, with a Chrome process consuming 100% CPU.
- 2018-08-20 13:57:54 UTC: Public access to the S3 bucket is revoked, ending a 56-minute window of exposure.
- 2018-08-20 15:15:04 UTC: SIEM triggers alert UR-AWS-20180820-0038 based on anomalous AWS API call frequency.

This attack targeted the AWS Cloud Control Plane and several Windows endpoints, originating from an exploit of the public-facing Apache web server gacrux (T1190- Exploit Public-Facing Application). After gaining initial access, the attacker escalated privileges (T1068- Exploitation for Privilege Escalation) to root to harvest unsecured IAM credentials (T1552-Unsecured Credentials) belonging to the bstoll account. These high-privilege keys were used to impair cloud defenses (T1562.00-Impair Defenses) by modifying the ACLs on the frothlywebcode S3 bucket, which was then used for unauthorized staging of internal technical data. The incident further escalated into resource hijacking (T1496-Resource Hijacking), with confirmed Monero mining causing 100% CPU exhaustion on workstations BSTOLL-L and MKRAEUS-L. While a similar attempt on BTUN-L was successfully defended, the attacker's ability to bypass MFA for API actions and compromise the cloud environment makes this a critical breach of our security posture.

Recommended Actions

To address the incident, the compromised AWS access keys must be deactivated immediately, and all credentials for the bstoll account should be reset to terminate unauthorized cloud access. Affected workstations and the web server require network isolation to facilitate the removal of the unauthorized svcvnc administrative account and the hdoor.exe malware. It is necessary to patch the Tomcat service to close the vulnerability that allowed for root-level privilege escalation. To prevent recurrence, the C2 IP address (45.77.53.176) must be blocked at the perimeter firewall, and a secret-scanning tool should be deployed across all GitHub repositories to identify and prevent future credential leaks.